Capabilities make it very easy to delegate just a small part of your authority to another user or process but can sometimes make it harder to track who has access to what, or to revoke access at a later time. Modern capability-based systems have developed techniques to address these drawbacks that you will learn about in later chapters. Aside from a few research operating systems in the 1970s, and some more recent working on capability-secure programming languages, capability security has existed outside of the mainstream. Many myths about apparent weaknesses in capability security have persisted from these early days and are addressed in the paper *Capability Myths Demolished* by Mark S. Miller, Ka-Ping Yee, and Jonathan Shapiro (2003, http://srl.cs.jhu.edu/pubs/SRL2003-02.pdf). Capabilities make a great fit for API security and have seen a resurgence in recent years due to the popularity of the related topic of token-based authentication (covered in chapters 4 and 5). OAuth 2, covered in chapter 7, can be seen as an attempt to layer capability-like restrictions on top of an identity-based access control system. We will cover capabilities in depth in chapter 9.

It is even possible to design applications and their APIs to not need any access control at all. A *wiki* is a type of website invented by Ward Cunningham, where users collaborate to author articles about some topic or topics. The most famous wiki is Wikipedia, the online encyclopedia that is one of the most viewed sites on the web. A wiki is unusual in that it has no access controls at all. Any user can view and edit any page, and even create new pages. Instead of access controls, a wiki provides extensive *version control* capabilities so that malicious edits can be easily undone. A log of edits provides some level of accountability as it is easy to see who changed what. Social norms develop to discourage antisocial behavior. Even so, large wikis like Wikipedia often have some explicit access control policies so that articles can be locked temporarily to prevent “edit wars” when two users disagree strongly.

1.5.3 Audit logging